Threat Analysis Report

รายงานวิเคราะห์การพบมัลแวร์ที่ปลอมตัวเป็นตัวติดตั้งซอฟต์แวร์ความปลอดภัย

19/02/2025

TLP:CLEAR

สำนักงานคณะกรรมการการรักษาความมั่นคงปลอดภัยไซเบอร์แห่งชาติ
๑๒๐ ชั้น ๗ อาคารซี ศูนย์ราชการเฉลิมพระเกียรติ ๘๐ พรรษา ๕ ธันวาคม ๒๕๕๐
ถนนแจ้งวัฒนะ แขวงทุ่งสองห้อง เขตหลักสี่ กรุงเทพมหานคร ๑๐๒๑๐ อีเมล saraban@ncsa.or.th

สารบัญ

สารบัญ 2
บทสรุปสำหรับผู้บริหาร 3
การวิเคราะห์เชิงเทคนิค 4
Technique Tactics and Procedures (MITRE ATT&CK) 7
Indicator of Compromise (IOCs) 8
แนวทางการเฝ้าระวัง ป้องกัน และรับมือ 10
อ้างอิง (References) 11

บทสรุปสำหรับผู้บริหาร

รายงานฉบับนี้นำเสนอการวิเคราะห์การแพร่กระจายของมัลแวร์ประเภท **Infostealer** ที่ถูกเผยแพร่ผ่านไฟล์ ZIP ซึ่งตั้งชื่อเลียนแบบซอฟต์แวร์ด้านความปลอดภัย เช่น Malwarebytes เพื่อหลอกล่อให้ผู้ใช้ติดตั้ง ภายในไฟล์ ZIP ประกอบด้วยไฟล์ .exe, .txt และ .dll ที่ถูกใช้ร่วมกันในการโจมตีแบบ **DLL Side-loading** โดยไฟล์ .exe จะโหลดไฟล์ DLL ที่เป็นอันตรายเพื่อปล่อยเพย์โหลดจริง ซึ่งเป็นมัลแวร์ Infostealer ที่มุ่งขโมยข้อมูลสำคัญ เช่น Credential และข้อมูลกระเป๋าเงินคริปโต

แคมเปญดังกล่าวถูกตรวจพบในช่วงเดือนมกราคมจากการวิเคราะห์ของ VirusTotal โดยพบความเชื่อมโยงของไฟล์ในแคมเปญผ่านรูปแบบไฟล์และค่า Hash ของไฟล์ .txt ภายใน ZIP ส่งผลให้สามารถระบุไฟล์ ZIP รูปแบบอื่น ๆ ที่คาดว่าอยู่ในแคมเปญเดียวกันได้เพิ่มเติม

หากในช่วงที่ผ่านมาองค์กรหรือผู้ใช้งานได้ติดตั้งโปรแกรมจากแหล่งที่ไม่เป็นทางการหรือไม่น่าเชื่อถือ ควรเร่งตรวจสอบความถูกต้องของไฟล์ติดตั้งโดยทันที รวมถึงตรวจสอบว่ามีโครงสร้างไฟล์หรือองค์ประกอบที่ตรงกับรูปแบบของแคมเปญนี้ หรือมีไฟล์ที่เป็นอันตรายแฝงอยู่ร่วมกับ ตัวติดตั้งหรือไม่

Execution Parents (463)

Scanned	Detections	Type	Name
2026-02-06	24 / 68	ZIP	reshade-download-github-io-9.50.4.zip
2025-11-09	27 / 65	ZIP	openiv-download-8.87.2.zip
2026-02-16	24 / 63	ZIP	gigabyte-rgb-fusion-2-github-io-6.64.5.zip
2026-02-21	26 / 65	ZIP	reshade-download-github-io-5.6.3.zip
2025-12-16	21 / 68	ZIP	logitech-g-hub-github-io-3.21.3.zip
2025-12-28	15 / 65	ZIP	unlocked-fps-windows-git-github-io-1.43.5.zip
2026-02-04	0 / 53	ZIP	shadowplay-download-github-io-7.42.1.zip
2025-12-04	24 / 69	ZIP	05e5a9bb50a54b8ba682d9741024d795a3302d79f9272f093702523b44c3bc49
2025-11-05	23 / 69	ZIP	r-e-p-o-download-game.github.io_1.41.3.zip
2026-02-03	34 / 68	ZIP	asus-liveupdate-github-io-8.72.7.zip

[ภาพที่ 1 ไฟล์ zip ที่ถูกระบุว่าพบไฟล์ txt ซึ่งมีค่า hash ตรงกัน]

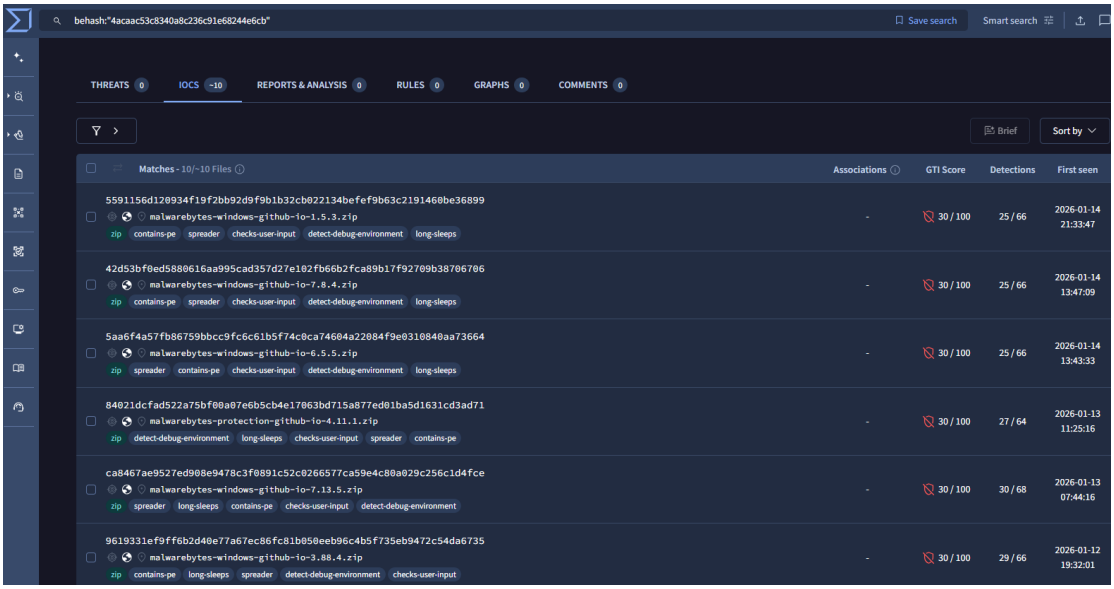
การวิเคราะห์เชิงเทคนิค

ลักษณะของไฟล์

ไฟล์ทั้งหมดในแคมเปญมีลักษณะที่เป็นไฟล์ zip โดยมีชื่อไฟล์เป็นรูปแบบ “malwarebytes-windows-github-io-X.X.X.zip” ภายในไฟล์จะมีโครงสร้างที่เหมือน ๆ กันโดยมีไฟล์ .dll ที่ทำหน้าที่เป็น loader, ไฟล์ txt ที่ใช้ชื่อว่า gitconfig.com.txt และ Agreement_About.txt และไฟล์ executable ที่คาดว่าจะเป็นไฟล์ที่ถูกต้องและดูเกี่ยวข้องกับ Malwarebytes

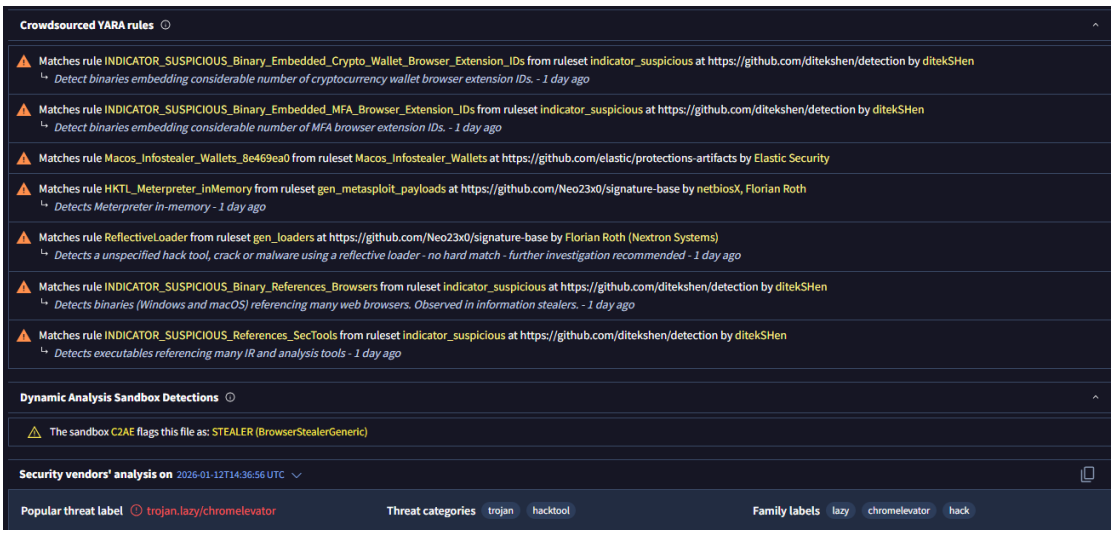
ลำดับการโจมตี (Attack Flow)

1. **Initial Access:** ในขั้นตอนของการเริ่มแรกของแคมเปญนี้เกิดขึ้นได้จากการดาวน์โหลดไฟล์ zip ที่มีชื่อตามรูปแบบ malwarebytes-windows-github-io-X.X.X.zip ซึ่งอาจจะแพร่กระจายผ่านการทำ Phishing หรือหลอกให้ดาวน์โหลดผ่านหน้าเว็บปลอม โดยใช้ความน่าเชื่อถือของชื่อ Malwarebytes ไฟล์ ZIP ที่เกี่ยวข้องถูกตรวจพบในช่วงวันที่ 11–15 มกราคม 2026 และมีลักษณะโครงสร้างภายในที่เหมือนกันทั้งหมด โดยสามารถจัดกลุ่มได้ด้วยค่า behash เดียวกัน ซึ่งบ่งชี้ว่าไฟล์เหล่านี้อยู่ในแคมเปญเดียวกัน

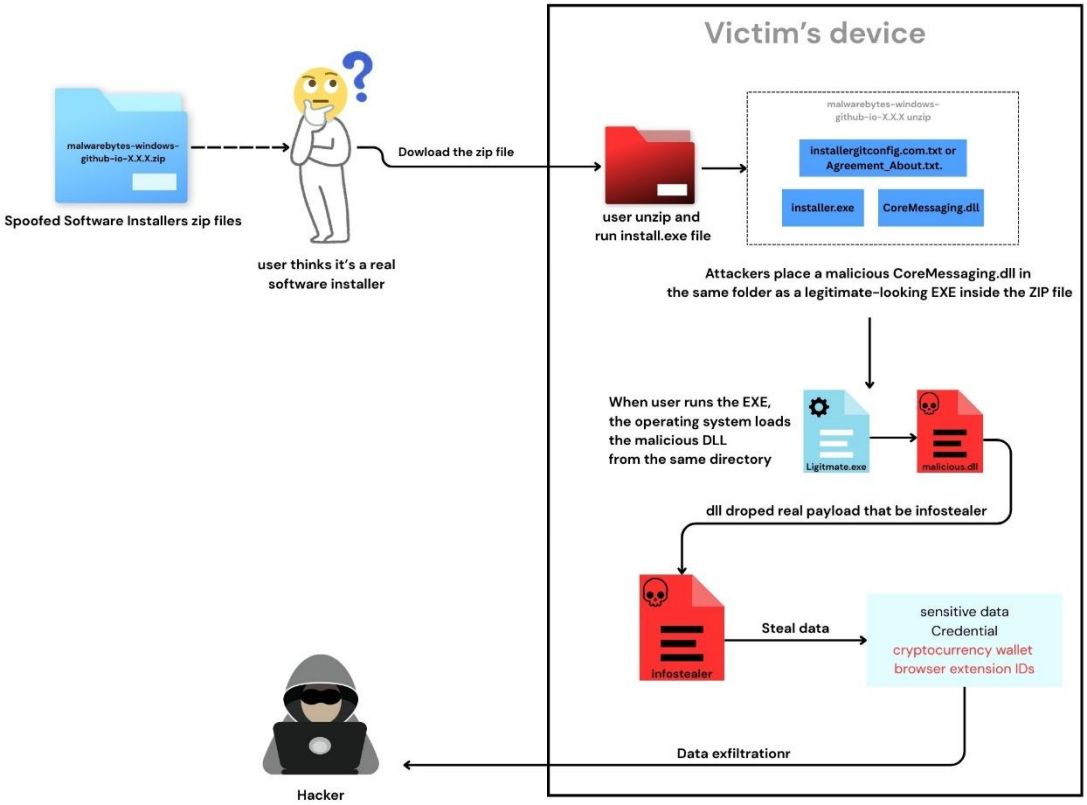


[ภาพที่ 2 ไฟล์ zip ที่มีค่า behash เดียวกันในแคมเปญ]

2. **Execution:** หลังจากที่เหยื่อได้ดาวน์โหลดไฟล์ zip และคลายการบีบอัด (unzip) แล้ว จะพบกับไฟล์ executable (exe) ที่ดูเหมือนไฟล์ที่ถูกต้อง เมื่อเหยื่อทำการเรียกใช้งานไฟล์ดังกล่าว ระบบปฏิบัติการ Windows จะเริ่มกระบวนการโหลดโมดูลที่จำเป็นสำหรับโปรแกรมตามปกติ และเป็นจุดเริ่มต้นของขั้นตอนการโจมตีถัดไปผ่านกลไก DLL Sideloading
3. **DLL Sideloading:** เทคนิคที่ใช้ในแคมเปญนี้คือ DLL Sideloading ซึ่งอาศัยกลไกการค้นหา DLL ของระบบปฏิบัติการ Windows โดยเมื่อโปรแกรมเรียกโหลด DLL โดยไม่ระบุ full path ระบบจะค้นหาไฟล์ DLL ตามลำดับการค้นหาซึ่งให้ความสำคัญกับโฟลเดอร์เดียวกับไฟล์ exe ก่อนตำแหน่งอื่น เช่น System32 ในกรณีนี้ ผู้ไม่หวังดีได้จัดวางไฟล์ DLL อันตรายไว้ในโฟลเดอร์เดียวกับไฟล์ exe ภายในไฟล์ zip เมื่อเหยื่อรัน exe ระบบจึงโหลด DLL ดังกล่าวโดยอัตโนมัติ เนื่องจากมีชื่อไฟล์ตรงกับที่โปรแกรมต้องการ
4. **Malicious DLL:** ไฟล์ DLL ที่ถูกโหลดมีชื่อว่า CoreMessaging.dll และทำหน้าที่เป็นเพย์โหลดหลักของระยะต้น (stage-1 payload) โดยบทบาทของไฟล์นี้คือการเป็น loader หรือ dropper สำหรับมัลแวร์ตัวจริงในขั้นถัดไป จากข้อมูล metadata ที่วิเคราะห์พบว่ามีการใส่ข้อมูลบริษัทและ signature ที่ไม่สอดคล้องกับซอฟต์แวร์จริง รวมถึงมี export function ที่ตั้งชื่อแบบสุ่ม ซึ่งเป็นพฤติกรรมที่พบได้บ่อยในมัลแวร์ที่พยายามหลีกเลี่ยงการตรวจจับด้วย signature-based detection เมื่อ DLL นี้ถูกโหลดเข้าสู่หน่วยความจำจะเริ่มกระบวนการภายในเพื่อเตรียมการปล่อย (drop) และเรียกใช้งานเพย์โหลดขั้นที่สอง ซึ่งก็คือ infostealer ที่ถูกออกแบบมาเพื่อขโมยข้อมูลจากเครื่องของเหยื่อ
5. **Payload drop:** หลังจากที่ DLL ทำงานจะเกิดกระบวนการดรอปไฟล์เพย์โหลดขั้นที่สองลงในระบบ จากข้อมูลใน sandbox execution chain แสดงให้เห็นว่า DLL มีการสร้างหรือเรียกใช้งานไฟล์เพิ่มเติมซึ่งเป็น infostealer พฤติกรรมของ infostealer ที่ตรวจพบได้แก่ การเข้าถึงข้อมูลที่จัดเก็บในเบราว์เซอร์ การดึงข้อมูล credential ที่บันทึกไว้ การตรวจสอบ extension ที่เกี่ยวข้องกับ cryptocurrency และการรวบรวมข้อมูลเกี่ยวกับกระเป๋าเงินดิจิทัล



[ภาพที่ 3 เพย์โหลดขั้นที่ 2 ที่ถูกแจ้งเตือนโดย YARA rules]



[ภาพที่ 4 แผนภาพการโจมตี]

Technique Tactics and Procedures

(MITRE ATT&CK)

MITRE ATT&CK คือฐานความรู้ที่รวบรวมและจัดหมวดหมู่กลยุทธ์และเทคนิคต่างๆ ที่ผู้ไม่หวังดีใช้ในการโจมตีทางไซเบอร์ โดยอ้างอิงจากเหตุการณ์ที่เกิดขึ้นจริง เพื่อให้ฝ่ายป้องกันสามารถเข้าใจและรับมือกับภัยคุกคามได้ดียิ่งขึ้น

Tactic	Technique ID	Technique Name
Execution	T1204.002	Malicious File
Defense Evasion	T1574.001	DLL
	T1036	Masquerading
	T1036.005	Match Legitimate Resource Name or Location
Collection	T1005	Data from Local System
Credential Access	T1555.003	Credentials from Web Browsers

Indicator of Compromise (IOCs)

Indicators of Compromise (IOCs) คือ ร่องรอยหรือหลักฐานทางดิจิทัลที่บ่งชี้ว่าระบบหรือเครือข่ายอาจถูกบุกรุกโดยผู้ไม่หวังดี ซึ่งทาง สกมช. ได้มีการแบ่งปันข้อมูล IOCs เหล่านี้ผ่านทางแพลตฟอร์ม MISP (Malware Information Sharing Platform) เพื่อเสริมสร้างความมั่นคงปลอดภัยไซเบอร์เรียบร้อยแล้ว โดยมีร่องรอยที่สามารถตรวจสอบได้ดังนี้

ร่องรอยที่สามารถตรวจสอบได้:

Behash

4acaac53c8340a8c236c91e68244e6cb

SHA 256

6773af31bd7891852c3d8170085dd4bf2d68ea24a165e4b604d777bd083caeaa
4294d6e8f1a63b88c473fce71b665bbc713e3ee88d95f286e058f1a37d4162be
5591156d120934f19f2bb92d9f9b1b32cb022134befef9b63c2191460be36899
42d53bf0ed5880616aa995cad357d27e102fb66b2fca89b17f92709b38706706
5aa6f4a57fb86759bbcc9fc6c61b5f74c0ca74604a22084f9e0310840aa73664
84021dcfad522a75bf00a07e6b5cb4e17063bd715a877ed01ba5d1631cd3ad71
ca8467ae9527ed908e9478c3f0891c52c0266577ca59e4c80a029c256c1d4fce
9619331ef9ff6b2d40e77a67ec86fc81b050eeb96c4b5f735eb9472c54da6735
a2842c7cfaadfba90b29e0b9873a592dd5dbea0ef78883d240baf3ee2d5670c5
4705fd47bf0617b60baef8401c47d21afb3796666092ce40fbb7fe51782ae280
580d37fc9d9cc95dc615d41fa2272f8e86c9b4da2988a336a8b3a3f90f4363c2
d47fd17d1d82ea61d850ccc2af3bee54adce6975d762fb4dee8f4006692c5ef7
606baa263e87d32a64a9b191fc7e96ca066708b2f003bde35391908d3311a463
fd855aa20467708d004d4aab5203dd5ecdf4db2b3cb2ed7e83c27368368f02bb
a0687834ce9cb8a40b2bb30b18322298aff74147771896787609afad9016f4ea
4235732440506e626fd4d0fffad85700a8fcf3e83ba5c5bc8e19ada508a6498e
cd1fe2762acf3fb0784b17e23e1751ca9e81a6c0518c6be4729e2bc369040ca5
f798c24a688d7858efd6efeaa8641822ad269feeb3a74962c2f7c523cf8563ff
0698a2c6401059a3979d931b84d2d4b011d38566f20558ee7950a8bf475a6959
1b3bee041f2fffcb9c216522afa67791d4c658f257705e0feccc7573489ec06f

231c05f4db4027c131259d1acf940e87e15261bb8cb443c7521294512154379b
ec2e30d8e5cacecdf26c713e3ee3a45ebc512059a64ba4062b20ca8bec2eb9e7
58bd2e6932270921028ab54e5ff4b0dbd1bf67424d4a5d83883c429cadeef662
57ed35e6d2f2d0c9bbc3f17ce2c94946cc857809f4ab5c53d7cb04a4e48c8b14
cfcf3d248100228905ad1e8c5849bf44757dd490a0b323a10938449946eabeee
f02be238d14f8e248ad9516a896da7f49933adc7b36db7f52a7e12d1c2ddc6af
f60802c7bec15da6d84d03aad3457e76c5760e4556db7c2212f08e3301dc0d92
02dc9217f870790b96e1069acd381ae58c2335b15af32310f38198b5ee10b158
f9549e382faf0033b12298b4fd7cd10e86c680fe93f7af99291b75fd3d0c9842
92f4d95938789a69e0343b98240109934c0502f73d8b6c04e8ee856f606015c8
66fba00b3496d61ca43ec3eae02527eb5222892186c8223b9802060a932a5a7a
e5dd464a2c90a8c965db655906d0dc84a9ac84701a13267d3d0c89a3c97e1e9b
35211074b59417dd5a205618fed3402d4ac9ca419374ff2d7349e70a3a462a15
6863b4906e0bd4961369b8784b968b443f745869dbe19c6d97e2287837849385
a83c478f075a3623da5684c52993293d38ecaa17f4a1ddca10f95335865ef1e2
43e2936e4a97d9bc43b423841b137fde1dd5b2f291abf20d3ba57b8f198d9fab
f001ae3318ba29a3b663d72b5375d10da5207163c6b2746cfae9e46a37d975cf
c67403d3b6e7750222f20fa97daa3c05a9a8cce39db16455e196cd81d087b54d
5ee9d4636b01fd3a35bd8e3dce86a8c114d8b0aa6b68b1d26ace7ef0f85b438a
e84b0dadb0b6be9b00a063ed82c8ddba06a2bd13f07d510d14e6fd73cd613fba

แนวทางการเฝ้าระวัง ป้องกัน และรับมือ

การเฝ้าระวัง (Monitoring)

- ตรวจสอบแหล่งที่มาของของโปรแกรม: ก่อนที่จะทำการดาวน์โหลดไฟล์และติดตั้ง ควรที่จะมีการตรวจสอบความน่าเชื่อถือของแหล่งที่มา รวมไปถึงตัวไฟล์ที่ได้ทำการดาวน์โหลดด้วยการเช็คด้วยค่าของ File hash
- เฝ้าระวังการแจ้งเตือนจากกอุปกรณ์ความปลอดภัย: เฝ้าระวังการแจ้งเตือนจากซอฟต์แวร์ความปลอดภัยต่างๆ เช่น Anti-Virus, EDR ที่รองรับ Custom YARA เนื่องจากเพย์โหลดของ infostealer นั้นสามารถที่จะถูกตรวจจับได้ด้วย YARA Rules

การป้องกัน (Prevention)

- เสริมการป้องกัน: พิจารณาใช้ซอฟต์แวร์ Endpoint Protection (EDR) ที่สามารถตรวจจับพฤติกรรมขโมยข้อมูล (credential stealing) หรือพฤติกรรมการโหลดไลบรารีผิดปกติและบล็อกก่อนเข้าสู่ระบบ
- เสริมสร้างความตระหนักรู้ด้านไซเบอร์: จัดการฝึกอบรมพนักงานให้รู้จักกับการทำ phishing และโปรแกรมปลอม พร้อมทั้งการโหลดไฟล์จากแหล่งที่น่าเชื่อถือ
- บังคับใช้นโยบายการติดตั้งซอฟต์แวร์เฉพาะที่ผ่านการอนุมัติ: หากเป็นอุปกรณ์ขององค์กรสามารถที่จะบังคับใช้นโยบายเพื่อให้สามารถติดตั้งซอฟต์แวร์ที่ได้รับอนุญาตเท่านั้น

การรับมือ (Response)

- แยกอุปกรณ์ที่ติดเชื้อ: หากตรวจพบการบุกรุก ให้รีบตัดการเชื่อมต่อเครื่องที่มีการบุกรุกนั้นออกจากเครือข่ายเพื่อป้องกันการแพร่กระจาย
- เก็บหลักฐานทางดิจิทัล: รักษาสภาพของเครื่องที่ติดเชื้อไว้สำหรับการวิเคราะห์หาสาเหตุและสืบสวน (Digital Forensics) เก็บสำรองไฟล์ zip ปลอมที่ดาวน์โหลดมา รวมไปถึงไฟล์ exe และ DLL ที่อยู่ภายใน
- กำจัดภัยคุกคาม: ทำการถอนการติดตั้งโปรแกรมที่เป็นอันตราย ลบไฟล์ต่าง ๆ ที่ถูกสร้างจากไฟล์นั้น ๆ
- กู้คืนระบบ: หากในกรณีที่ไม่ทราบถึงการดำเนินการของมัลแวร์ว่าได้มีการฝังตัวในระบบอย่างไรบ้าง ให้ดำเนินการกู้คืนระบบจาก Backup ที่ปลอดภัยซึ่งได้รับการยืนยันว่าไม่มีการติดเชื้อหรือติดตั้งโปรแกรมที่เป็นอันตรายดังกล่าว
- รายงานเหตุการณ์: แจ้งเหตุการณ์ไปยังหน่วยงานที่เกี่ยวข้องภายในองค์กรและหน่วยงานด้านความมั่นคงปลอดภัยไซเบอร์

อ้างอิง (References)

1. VIRUSTOTAL's Blog "New Infostealer Campaign Targets Users via Spoofed Software Installers"
https://blog.virustotal.com/2026/01/malicious-infostealer-january-26.html

แบบประเมินรายงานข่าวกรองไซเบอร์

https://dg.th/nsexlfob51

จัดทำโดย

ฤทธิ์นภา ประเสริฐศรี

ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์ สำนักประสานงาน
ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ
โทร: 02 114 3531 อีเมล: cti_misp@ncsa.or.th